Enterprise Shadow AI Discovery Platform

Solution Architecture Document (SAD)

Discover → Correlate → Reconcile → Assess → Govern

Item	Detail
Document	Solution Architecture Document
Version	0.3 (Draft for review)
Prepared by	Bimal Kumar Upadhyay, Technical Architect
Status	Draft – not yet reviewed by ARB
Reviewers	Ganesh Perumal
Related documents	Shadow_AI_Discovery_Requirements_v0.4.docx; Shadow_AI_Discovery_Recommended_Approach.xlsx; Shadow_AI_Discovery_Wireframe_v2.html; kickoff meeting transcript; prototype v0.2

Version history

Version	Summary of changes
0.1	Initial solution architecture document
0.2	Added Section 3.5 “Confidence and risk scores explained”
0.3	Added Section 8 “Demonstrator architecture (Wireframe v2)” with two new diagrams, collectors, join rules J1–J6, decision rules R1–R4, scoring rubric, demo scenarios S1–S7, component mapping and alignment items; added Appendix B screen catalogue with 12 wireframe screenshots for development; renumbered later sections; added gaps G10–G11, risk R15 and question Q12

*Reading guide: **[TBD –to confirm]** marks values not yet agreed. (proposed) marks architect recommendations that need approval. Everything else is taken from the requirements v0.4, the workbook, the kickoff meeting or Wireframe v2.*

Version history 1
1. Introduction 5
1.1 Purpose 5
1.2 Scope 5
1.3 Audience 5
1.4 Delivery context 5
2. Business context 6
2.1 Problem statement 6
2.2 Who is impacted 6
2.3 Expected outcomes 6
2.4 Success measures 6
3. Requirements summary 7
3.1 Capabilities 7
3.2 Inputs and outputs 7
3.3 Key business rules 7
3.4 Non-functional targets 7
3.5 Confidence and risk scores explained 8
4. Constraints, assumptions and dependencies 11
4.1 Constraints 11
4.2 Assumptions 11
4.3 Dependencies 11
5. Current state (AS-IS) 12
5.1 Gaps 12
6. Architecture principles 13
7. Logical architecture (TO-BE) 14
7.1 Components and responsibilities 14
7.2 Boundaries 15
7.3 Prototype and wireframe mapping 15
8. Demonstrator architecture (Wireframe v2) 16
8.1 Processing pipeline 16
8.2 Collectors 17
8.3 AI signature catalogue (extract) 17
8.4 Join rules (how clues are linked) 17
8.5 Decision rules (first match wins) 17
8.6 Demonstrator scoring rubric 17
8.7 Demo scenarios S1–S7 18
8.8 Reference data used by the demonstrator 19
8.9 Mapping to the logical architecture 19
8.10 Alignment items for the development team 20
9. Technology architecture 21
9.1 Demonstrator components (Wireframe v2) 21
9.2 Architecture Decision Records 21

9.3 Proofs of concept 22
10. Data architecture 23
10.1 Data ownership 23
10.2 Field classification 23
10.3 Data lifecycle 23
10.4 Demonstrator data entities 23
11. Integration architecture 24
11.1 Integration rules 24
12. Security architecture 25
12.1 Threat model (STRIDE) 25
12.2 Layered controls 25
12.3 Zero Trust 25
12.4 AI safety of the platform's own GenAI 25
12.5 Employee monitoring and privacy 26
12.6 Demonstrator safeguards 26
13. Deployment and operations 27
13.1 Hosting 27
13.2 Environments 27
13.3 CI/CD 28
13.4 Scaling and observability 28
13.5 Backup and disaster recovery 28
13.6 Run model 28
14. Failure and risk analysis 29
14.1 Failure modes 29
14.2 SPOFs, bottlenecks and lock-in 29
14.3 Risk register 29
15. Validation and traceability 31
15.1 Traceability summary 31
15.2 Gaps to close before sign-off 31
15.3 Sign-off 31
15.4 Demonstrator vs target 32
16. Roadmap 33
17. Open questions 34
Appendix A. Glossary 35
Appendix B. Screen catalogue (Wireframe v2) for development 36
B.1 Demo scenarios 36
B.2 Run discovery – before the run 37
B.3 Run discovery – after the baseline run 38
B.4 Clue map 39
B.5 AI signals 40
B.6 AI usage candidates 41
B.7 Candidate detail (C-002 example) 42

B.8 Issues 43
B.9 Issue detail 44
B.10 Rules & reference 45
B.11 Run discovery – after live activity (S7) 46
B.12 Issues after S7 47

1. Introduction

1.1 Purpose

This document describes the solution architecture for the Shadow AI Discovery Platform. It explains how the platform discovers AI usage across the Bank, checks it against approved AI, scores confidence and risk, and routes each finding to an owner, and how it is built, secured, deployed and operated.

1.2 Scope

In scope	Out of scope (by default)
Discovery of AI apps, models, APIs, SDKs, agents, MCP servers and AI SaaS	Collecting prompts, AI responses or document content
Correlation of signals from multiple enterprise systems	Storing real API keys or secret values
Reconciliation with the approved AI inventory	Automatic blocking without human review
Confidence and risk scoring	Replacing existing security tools
Cases, exceptions, governance workflow, dashboards, KPIs and audit	Integration with an external ticketing tool (ServiceNow removed in v0.4)

1.3 Audience

Architecture Review Board, Enterprise Architecture, Security Architecture, AI Governance, Risk and Compliance, Privacy/Legal, Infra/DevOps/SRE and the delivery team. Section 8 and Appendix B are written mainly for the development team.

1.4 Delivery context

The first deliverable is a prototype demonstrator. The demonstrator runs on an AVD with fictional, metadata-only data (Section 8). This document describes both the demonstrator and the target production architecture, and states clearly where they differ.

2. Business context

2.1 Problem statement

AI is being adopted across the Bank through approved services, SaaS products, developer tools and teams' own applications. Because evidence of this usage is spread across many systems and isn't checked against the approved AI inventory, the Bank cannot reliably see where AI is used, whether that use is approved, or how risky it is. This creates potential data, regulatory, security and third-party risk.

Example: an employee pastes customer data into a public AI website. The proxy and DLP systems record each part of it, but no one sees the full picture or knows the site isn't approved.

2.2 Who is impacted

Group	Impact
Customers	Data could be exposed to unapproved AI services
Leadership / board	Can't answer “Where do we use AI, and are we in control?”
AI Governance	Can't approve, restrict or stop AI they can't see
Security (SOC)	Data leaks and exposed API keys go undetected or unlinked
Risk and Compliance	Can't show auditors or regulators that AI is under control
Application owners	Don't know whether their AI use is allowed
Employees and business teams	May break policy without knowing. The aim is safe use of AI, not a ban.

2.3 Expected outcomes

Today	Target
Only approved AI is visible	All AI use is discovered
Clues sit in separate tools	Clues are joined into one finding
No check against approved AI	Every finding is marked Approved or Unknown
Every finding looks equally urgent	Confidence and risk are scored separately
No owner or action	Each finding has an owner and a response
Hard to prove control	Auditable evidence and reports

2.4 Success measures

Demonstrator: the demo runs end to end (discover, correlate, reconcile, score, decide); approved and unapproved AI are clearly told apart; risk is explained in plain language.

KPI	What it shows	Target
Unknown AI assets found	Shadow AI is visible	[TBD–to confirm]
% findings matched to approved list	Inventory coverage	[TBD–to confirm]
Time to triage high-risk findings	Speed of response	[TBD–to confirm]
Time to resolve by risk level	Case handling works	[TBD –to confirm]
High-risk findings by business unit	Where risk sits	Trend
False-positive rate	Results are trusted	[TBD –to confirm]
Sources connected vs planned	Programmed progress	Per roadmap

3. Requirements summary

Full requirements, acceptance criteria and priorities are in Requirements v0.3. This section summarizes what drives architecture.

3.1 Capabilities

#	Capability	What it does	Requirements
1	Signal collection	Pulls AI-related metadata from enterprise systems	FR-01
2	Normalization	One common event format	FR-02
3	AI catalogue and detection	Recognizes AI providers from domains, SDKs, sign-ins, agent indicators	FR-03, FR-04, FR-20
4	Correlation	One finding per AI asset; duplicates merged	FR-05, FR-06
5	Reconciliation	Check against approved AI inventory	FR-07
6	Scoring	Confidence and risk, separately (see 3.5)	FR-08, FR-09
7	Governance	Status and recommended action	FR-10
8	Case management	Cases, owners, exceptions, escalation	FR-11, FR-21, FR-22
9	Explanation and dashboard	Plain language, ordered by risk	FR-12, FR-13, FR-25
10	Audit, reporting, controls	Audit log, KPIs, source approval gate	FR-18, FR-19, FR-23, FR-24

3.2 Inputs and outputs

Inputs	Outputs
Network/proxy, identity/OAuth, secret findings, DLP, endpoint/IDE, code dependencies, cloud resources, SaaS/CASB, agents/MCP, procurement	Finding record, Confidence score, Risk score, status, recommended action, case, plain-language explanation, dashboard and KPIs, audit log
Reference: approved AI inventory, CMDB, AI catalogue	Demonstrator: planted AVD data and log files (Section 8)

3.3 Key business rules

- BR-01 A signal counts as AI usage only if it matches the AI catalogue.
- BR-02 Several clues for the same provider and app/user become one finding.
- BR-03 An SDK in code is a candidate, not proof of use. BR-04 A payment shows purchase, not use.
- BR-06/07/08 Provider and app must both match the inventory to be Approved; otherwise, Unknown, even for an approved provider.
- BR-09 Confidence and risk are never combined. BR-10 Workbook weights must be calibrated by the Bank.
- BR-15 Restrict and Block are always human decisions. BR-16 False Positive needs a reason.
- BR-19/20 Metadata only; secrets kept as fingerprints. BR-21 Read-only connectors; discovery and blocking identities separate.
- BR-23 No new telemetry source without Privacy/Legal approval. BR-25 GenAI only explains; it never decides.

3.4 Non-functional targets

Area	Target	Status
Availability (NFR-11)	99.5% monthly	Proposed
Event-to-finding, streaming (NFR-09)	≤ 15 minutes; batch sources ≤ 24 hours	Proposed

Area	Target	Status
Dashboard freshness (NFR-12)	≤ 15 minutes	Proposed
API response	95% of requests < 2 seconds	Proposed
Event volume (NFR-10)	Sized from real proxy/SWG volume	[TBD – Bank to confirm]
Scalability (NFR-17)	New sources as plug-in modules	Defined
RPO / RTO (NFR-16)	RPO ≤ 1 hour; RTO ≤ 4 hours; audit log zero loss	Proposed
Retention (NFR-13/14)	Not indefinite for user activity	[TBD – Bank to confirm]
Data residency (NFR-15)	Bank-approved region	[TBD – Bank to confirm]
Security (NFR-01 to NFR-08)	Read-only, separation of duties, no raw secrets, metadata only, case-based content access, vault, audit, permission validation	Defined
AI safety (GENAI-01 to 07)	Registered, metadata only, advisory, human review, logged, approved endpoint, works without GenAI	Defined

3.5 Confidence and risk scores explained

Every finding gets two separate scores from 0 to 100. They answer two different questions and are never added together (BR-09).

Score	Question it answers	Analogy
Discovery Confidence	How sure are we that AI is really being used here?	A detective collecting clues: one clue is a hint; several clues pointing the same way make a strong case
AI Risk	If this AI use is real, how much harm could it cause the Bank?	A building inspector: what is stored inside, who can get in, and are there locks?

Factor weights come from the workbook Scoring Framework and must be calibrated by the Bank. Points within each factor in these examples come from prototype v0.2. Wireframe v2 uses a more detailed rubric (Section 8.6); the team should agree one rubric (gap G10).

3.5.1 Confidence score

Clue	Points	Simple meaning
Direct evidence	30	We actually saw traffic to an AI service, or an AI resource running
Identity correlation	20	We know which app, person or device it is
Technology correlation	20	Supporting technical signs, such as an AI SDK in code or an AI key
Recurrence	15	It happened more than once
Independent corroboration	15	Two or more different systems saw it

Example 1 – weak clue, low confidence. A code scan finds the anthropic package in a marketing app. Nothing else.

Clue	Points	Why
Direct evidence	0	No traffic seen
Identity correlation	20	We know the app
Technology correlation	10	SDK only
Recurrence	0	Seen once
Independent corroboration	0	Only one system
Total	**30 → Low**	**A hint, not proof – the package may never be used**

Example 2 – several clues, high confidence. For the same app we also find an Anthropic API key in the code, and network logs show the app calling the Anthropic API on three different days.

Clue	Points	Why
Direct evidence	30	Network traffic seen
Identity correlation	20	We know the app
Technology correlation	20	Network and code signs together
Recurrence	15	Three days
Independent corroboration	15	Code, secret scan and network all saw it
Total	**100 → High**	**We are very sure this app uses Anthropic**

In one line: the confidence score measures how strong the evidence is, not how bad the situation is.

3.5.2 Risk score

Factor	Max points	Simple question
Data sensitivity	25	How sensitive is the data (public, internal, confidential, restricted)?
Autonomy and permissions	20	Can the AI act on its own – write, transact or execute?
External exposure	15	Does the data go to a public, external service?
Business criticality	15	Is it used in an important area such as lending, risk, finance or trading?
Regulatory / customer impact	15	Could it cause legal, conduct or customer harm?
Control weakness	10	Is it missing an owner, approval, gateway or logging?

Example 1 – approved app, low risk. The document-summary app uses Mistral, which is on the approved list, with internal data only.

Factor	Points	Why
Data sensitivity	8	Internal data
Autonomy	5	Summarises only; no actions
External exposure	5	Approved service, not a public consumer site
Business criticality	8	Medium-importance app
Regulatory impact	5	No customer-sensitive data
Control weakness	0	Approved, with an owner
Total	**31 → Low**	**Monitor; no action needed**

Example 2 – unapproved AI agent, high risk. A trading bot uses OpenAI from an app that isn't approved, handles confidential data, and can write to a trading system.

Factor	Points	Why
Data sensitivity	18	Confidential data
Autonomy	20	Agent with write access
External exposure	15	Public external API
Business criticality	15	Markets / trading
Regulatory impact	15	Confidential, regulated area
Control weakness	10	Not approved; no review
Total	**93 → High**	**Investigate urgently**

Example 3 – one employee, high risk. An employee in Retail Lending uploads restricted customer data to a public AI website.

Factor	Points	Why
Data sensitivity	25	Restricted data
Autonomy	5	A person, not an agent
External exposure	15	Public AI website
Business criticality	8	Medium criticality
Regulatory impact	15	Customer data
Control weakness	10	Not approved
Total	**78 → High**	**DLP also flagged the data leaving the Bank, so this goes to Incident Management**

In one line: the risk score measures how much harm the AI use could cause, not how sure we are that it's happening.

3.5.3 Bands and how the two scores work together

Band	Score range	Status
Low	0–39	Proposed
Medium	40–69	Proposed
High	70–100	Proposed

Case	Confidence	Risk	Meaning
Approved Mistral app used daily	High	Low	We're sure it's used, and it's fine – monitor
Marketing app calling Anthropic (unapproved)	High	Medium	Real and unapproved – investigate
Trading bot agent with write access	High	High	Real and dangerous – urgent investigation
One-off upload of restricted data to a public AI site	Medium	High	Less certain, but urgent if true – incident
AI package found in code only	Low	Medium	Probably not used yet – monitor and confirm

Routing uses both scores (Section 9.4 of Requirements v0.4). The demonstrator uses the simpler decision rules R1–R4 (Section 8.5). Restrict and Block remain human decisions.

Where it lives	Detail
Component	C6 Scoring Engine (Section 7); weights held as versioned configuration (ADR-002)
Prototype	app/engine/scoring.py; bands in app/config.py
Wireframe v2	Candidate detail screen shows each factor's points and reason (Appendix B, Screen B.7)

4. Constraints, assumptions and dependencies

4.1 Constraints

Area	Constraint
Timeline	Demonstrator ready (~3 weeks from kickoff; date TBC)
Scope	First deliverable is a demonstrator, not production
Approved AI	OpenAI and Mistral APIs on approved cloud are known, allowed AI
Platforms	No platform mandated; cases managed in-platform (no ServiceNow)
Data collection	Metadata only; no prompts, responses, documents or real secrets
Access	Read-only connectors; discovery and blocking identities separate
Retention / residency	No indefinite retention; Bank-approved regions [TBD –to confirm]
Employee monitoring	Browser/endpoint data need privacy governance review
Budget	[TBD –to confirm]

4.2 Assumptions

#	Assumption	Confirm with
A1	Demonstrator uses fictional data planted on an AVD (Wireframe v2)	Programmed lead
A2	Prototype stack is Python + FastAPI, GenAI off by default	Team
A3	An approved AI inventory exists or can be built	AI Governance
A4	Workbook permissions are indicative	Platform owners, Security
A5	Scoring weights calibrated in pilot	Risk / AI Governance
A6	Bands and routing are proposed defaults	AI Governance
A7	Production on Bank-approved cloud, likely Azure, with Entra ID, Key Vault, managed identity	EA
A8	GenAI, if enabled, uses an approved endpoint with metadata only	AI Governance
A9	Platform reads from existing security tools; doesn't replace them	Security

4.3 Dependencies

#	Dependency	Impact if missing
D1	Approved AI inventory and owner	Can't tell Approved from Unknown
D2	CMDB / asset data	Wrong owners; false 'unmatched'
D3	Read access to proxy, Entra ID, DLP, secret scanning, cloud	Demo only; no real discovery
D4	Data classification	Weak DLP links and risk scoring
D5	Privacy, Legal, HR approval	Endpoint/browser/IDE sources can't go live
D6	Connector licenses and API access	Onboarding delays
D7	Specification with team support	Gaps in technical detail
D8	Confirmed event date	Can't plan the build
D9	AVD demo environment with Ollama, LiteLLM gateway, MCP server and proxy/DLP add-on	Demonstrator scenarios can't be planted

5. Current state (AS-IS)

Today only approved AI (OpenAI and Mistral APIs) is visible. Evidence of other AI use is spread across tools owned by different teams, and nothing combines it or checks it against the AI inventory. The tools below are the workbook's likely Bank solutions and must be confirmed.

Source	Likely tools today	AI-related control today
Network / proxy	SWG, DNS security, firewall, Zscaler, Netskope, Entra GSA	URL category filtering
Identity	Entra ID, Okta, Ping, SailPoint	App registrations, OAuth consent
DLP	Purview, Symantec, Forcepoint	Sensitive data alerts, not linked to AI
Endpoint / IDE	Defender, CrowdStrike, Intune, JAMF	Software inventory
Code / secrets	GitHub, GitLab, Azure DevOps, Snyk, Vault, Key Vault	Secret and dependency scanning
Cloud	Azure Resource Graph, AWS Config, GCP CAI, CSPM	Resource inventory and policy
SaaS	Defender for Cloud Apps, Netskope	Cloud app discovery
Procurement	Ariba, Coupa, ERP, expense	Vendor and expense records
Asset data	CMDB, application portfolio	Applications and owners
SIEM	Sentinel, Splunk, QRadar	Security alerting

5.1 Gaps

#	Gap	Effect
G1	Each tool sees only part of AI use	No complete picture
G2	Signals aren't joined	Duplicate or weak alerts
G3	No check against approved inventory	Can't tell Approved from Shadow AI
G4	No separate confidence/risk scoring	Everything looks equally urgent
G5	DLP not linked to AI destinations	AI data leaks not recognised
G6	CMDB ownership incomplete	Findings without owners
G7	Procurement not linked to AI governance	AI bought outside sourcing unnoticed
G8	Agents and MCP servers not inventoried	Unknown high-privilege agents
G9	No AI-specific owner, workflow or audit	Can't prove control

6. Architecture principles

Principle	Meaning for this solution
Multi-signal discovery	Combine identity, network, endpoint, code, cloud, SaaS, DLP and procurement; no single source is enough
Correlation, not binary detection	Join clues before declaring a finding
Separate confidence from risk	“How sure” and “how dangerous” are different scores (Section 3.5)
Inventory reconciliation	Every finding is checked against approved AI
Privacy-preserving collection	Metadata and fingerprints only
Tiered response	Monitor, investigate, approve, restrict, block or incident
Least privilege and separation of duties	Read-only discovery; enforcement stays in existing tools
GenAI is advisory	Rules decide; GenAI explains
Explain every decision	Evidence, points per factor and the rule that fired are always visible (Wireframe v2)
Product-neutral, pluggable sources	One connector per source behind a common interface

7. Logical architecture (TO-BE)

The platform has 13 components in five layers plus shared services. Each component has one responsibility and a clear “does not do” boundary.

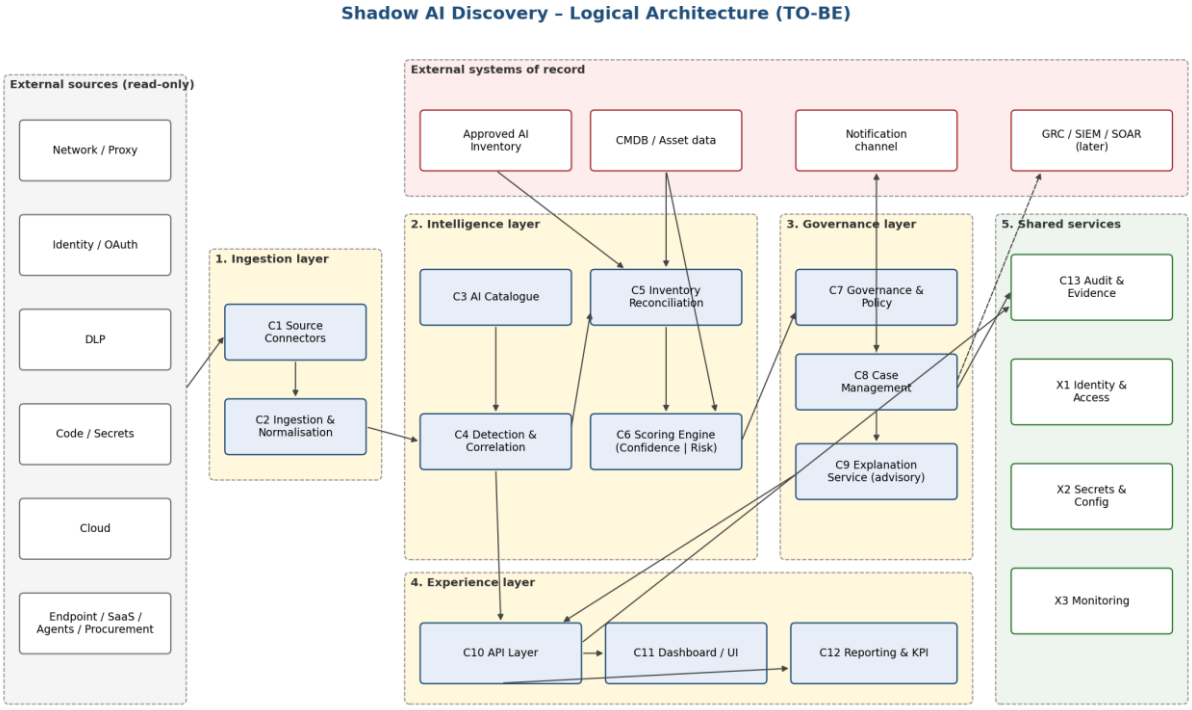


Figure 1 – Logical architecture

7.1 Components and responsibilities

#	Component	Responsible for	Owns	Does not do
C1	Source Connectors	Read metadata per source, read-only	Connector settings, checkpoints	Detection, scoring, rules
C2	Ingestion & Normalization	Validate, map to common format, drop noise	Normalized events	Decide what is AI
C3	AI Catalogue	AI providers and indicators; versioned	Catalogue and history	Match events
C4	Detection & Correlation	Match catalogue; one finding per asset	Findings	Approval check, scoring
C5	Inventory Reconciliation	Check against approved inventory	Match result	Edit the inventory
C6	Scoring Engine	Confidence and Risk with factors	Scores, bands, weights	Status or action
C7	Governance & Policy	Status, recommended action, case need	Policy rules, status	Case tracking; never blocks
C8	Case Management	Cases, owners, due dates, exceptions, escalation	Cases, exceptions	Change scores or rules
C9	Explanation Service	Plain-language summary (template or GenAI)	Nothing authoritative	Change detection, score, status
C10	API Layer	Single entry point; access checks	None	Business logic
C11	Dashboard / UI	Findings, cases, analyst actions	None	Direct database access
C12	Reporting & KPI	Trends, KPIs, coverage	Report snapshots	Change findings

#	Component	Responsible for	Owns	Does not do
C13	Audit & Evidence	Append-only log	Audit log	Edit or delete entries
X1–X3	Shared services	Identity, secrets/config, monitoring	Roles, credentials, metrics	–

7.2 Boundaries

Boundary	Rule
Platform ↔ sources	Read-only; metadata only
Discovery ↔ enforcement	Platform recommends; existing tools enforce, under a separate identity
Platform ↔ inventory, CMDB	External systems of record; platform reads only
Rules ↔ GenAI	GenAI explains; rules decide
Correlation ↔ Reconciliation	C4: is it AI and which asset? C5: is it approved?
Scoring ↔ Governance	C6 calculations; C7 decides what it means
Governance ↔ Case	C7 decides the action; C8 manages the work
UI ↔ data	UI only via API; every write audited

7.3 Prototype and wireframe mapping

Prototype v0.1 code: C1 connectors/, C3 catalog.py, C4 engine/correlation.py, C5 inventory.py, C6 engine/scoring.py, C7 engine/governance.py, C8 pipeline.py + store.py, C9 ai/explainer.py, C10 main.py, C11 static/index.html, C13 audit in store.py. Wireframe v2 mapping is in Section 8.9.

8. Demonstrator architecture (Wireframe v2)

This section describes the architecture of the event demonstrator as designed in Shadow_AI_Discovery_Wireframe_v2.html.

The demonstrator runs on an AVD and scans only C:\ShadowAI-Demo. AI activity is deliberately planted for seven scenarios (S1–S7); the engine is not told about them and must find each one from the traces it leaves. All data is fictional.

Audience takeaway	How the demonstrator shows it
1. It finds AI on its own	From code, keys, computers, agents, internet traffic and data movement
2. It links the clues	Clues that share a repo, key, user + website or server become one case
3. It tells good from risky	Approved use stays quiet; shadow and risky use is raised
4. It explains every decision	Evidence, points per factor and the rule that fired

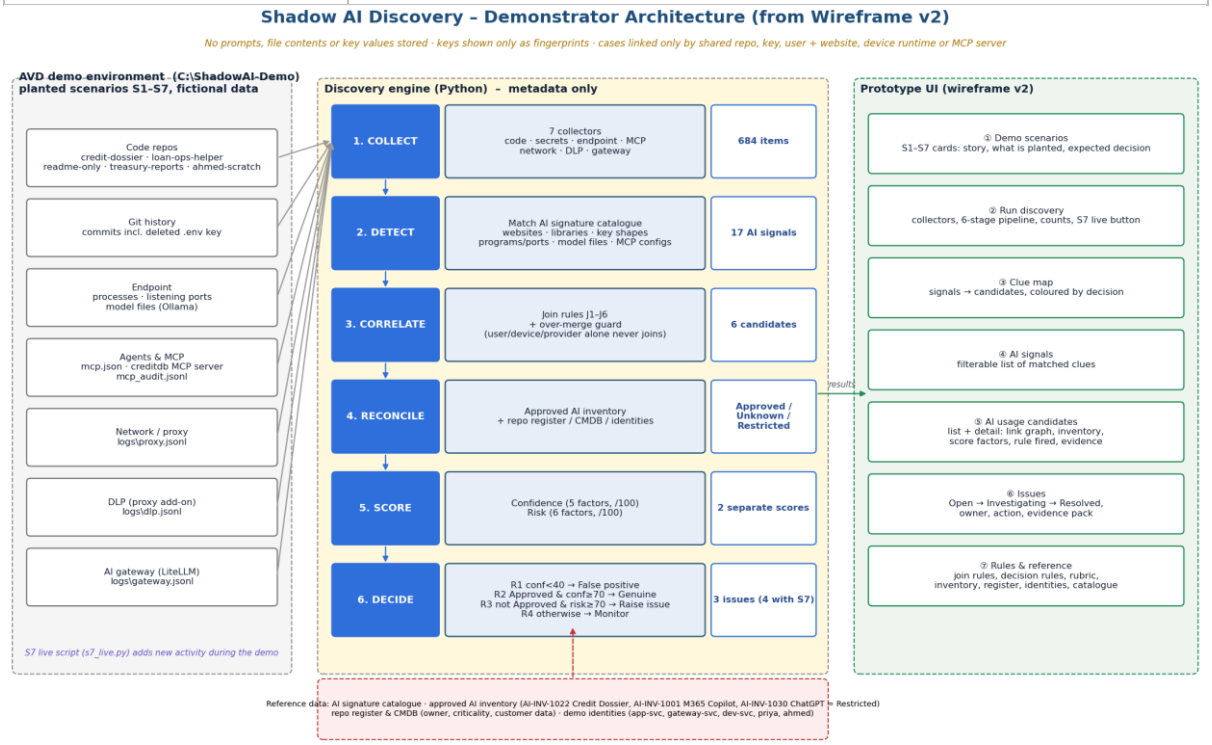


Figure 3 – Demonstrator architecture (derived from Wireframe v2)

8.1 Processing pipeline

Stage	What it does	Output	Demo result (baseline / with S7)
1. Collect	7 collectors read files, git history, processes, ports, configs and logs	Items scanned	684 / 692
2. Detect	Match items against the AI signature catalogue	AI signals (clues)	17 / 20
3. Correlate	Link signals using join rules J1–J6	AI usage candidates	6 / 7
4. Reconcile	Check each candidate against the approved inventory, repo register and CMDB	Approved, Unknown or Restricted	6 / 7
5. Score	Confidence (5 factors) and Risk (6 factors), each out of 100	Two scores with reasons	6 / 7
6. Decide	Apply decision rules R1–R4 (first match wins)	Decision and issues	3 / 4 issues

8.2 Collectors

Collector	Reads (demo)	Items baseline	Extra with S7	Production equivalent (Section 11)
Code & dependencies	4 repos · 96 files	96	+1	INT-07
API keys & secrets	files + 13 commits	109	+1	INT-03
Endpoint & local models	processes, ports, endpoint\ folder	220	–	INT-06
Agents & MCP	configs, servers, audit	5	–	INT-10
Network / proxy	logs\proxy.jsonl	233	+5	INT-01
DLP (proxy add-on)	logs\dlp.jsonl	1	+1	INT-04
AI gateway	logs\gateway.jsonl	20	–	INT-08

8.3 AI signature catalogue (extract)

Type	Signatures
Websites	api.openai.com, chatgpt.com, api.anthropic.com, api.mistral.ai, gemini.google.com
Libraries	openai, anthropic, mistralai, langchain, ollama
Key shapes	sk-…, sk-proj-…, sk-ant-…
Programs / ports	ollama : 11434, lmstudio : 1234
Model files	.gguf, .safetensors, .onnx, Ollama blobs
Agent configs	mcp.json, claude_desktop_config.json

8.4 Join rules (how clues are linked)

Rule	Links two clues when…	Used in
J1	Same repo/app name and same AI provider	S1, S2
J2	Same credential fingerprint	Key reuse
J3	Repo's service account or commit author = proxy user, and same provider	S2, S7
J4	Network + DLP: same user, same website, within ±2 minutes	S3, S7
J5	Same device and same AI runtime (process ↔ port ↔ model file)	S4
J6	MCP config server ↔ running server ↔ tool-call audit	S5

Over-merge guard: the same user, device or provider alone never links clues. That is why Ahmed's local model (S4), agent (S5) and Anthropic use (S7) stay three separate cases.

8.5 Decision rules (first match wins)

Rule	Condition	Decision
R1	Confidence < 40	False positive
R2	Approved AND confidence ≥ 70	Genuine
R3	Not approved AND risk ≥ 70	Raise issue
R4	Otherwise	Monitor

8.6 Demonstrator scoring rubric

The wireframe uses the workbook factor weights with more detailed points rubric inside each factor. Thresholds and weights are configurable.

Confidence factor (max)	Points rubric
Direct evidence (30)	Runtime activity 30 · MCP server/credential 25 · SDK 15 · model file 10 · doc mention 5
Identity link (20)	Direct from evidence 20 · via repo register 10
Technology correlation (20)	Signal types: ≥3 → 20 · 2 → 15 · 1 → 5
Recurrence (15)	Events: ≥10 → 15 · 2–9 → 10 · 1 → 0
Independent channels (15)	≥3 → 15 · 2 → 10 · 1 → 0

Risk factor (max)	Points rubric
Data sensitivity (25)	Customer PII 25 · Confidential 20 · exposed key 15
External exposure (15)	Direct external 15 · via gateway 5 · local 0
Autonomy / permissions (20)	Write-capable agent 20 · programmatic/read 10 · human/local 5
Business criticality (15)	High 15 · Medium 10 · Low 5 · unknown 8
Regulatory / customer (15)	PII or write to customer store 15 · Confidential / customer-data app 10
Control weakness (10)	+5 not approved · +5 bypass / plaintext key / no owner

8.7 Demo scenarios S1–S7

#	Scenario	Clues (channels)	Join	Inventory	Conf.	Risk	Decision	Owner
S1	Approved Credit Dossier: credit-dossier → Mistral via gateway	4 (Code, Gateway, Network)	J1	Approved AI-INV-1022	100	40	Genuine	Credit Technology
S2	Developer shortcut: loan-ops-helper → OpenAI direct, key in git history	4 (Code, Secret, Network)	J1, J3	Unknown	100	75	Raise issue	Ravi Menon (repo owner)
S3	Customer PII uploaded to chatgpt.com (blocked)	2 (Network, DLP)	J4	Restricted AI-INV-1030	85	85	Raise issue	Retail Lending line manager
S4	Local Ollama model on Ahmed's desktop	3 (Endpoint)	J5	Unknown	80	25	Monitor	Risk Analytics
S5	risk-agent → creditdb via MCP with WRITE tool	3 (MCP)	J6	Unknown	75	80	Raise issue	Credit Data Platform
S6	README mentions OpenAI only	1 (Code)	–	No match	20	10	False positive	–
S7 (live)	Ahmed calls Anthropic with Confidential data (DLP blocked)	3 (Code, Network, DLP)	J3, J4	Unknown	95	75	Raise issue	Risk Analytics

Scores are totals of the factor points in Wireframe v2. treasury-reports is the control repo: scanned, but nothing matched, so no signal and no candidate.

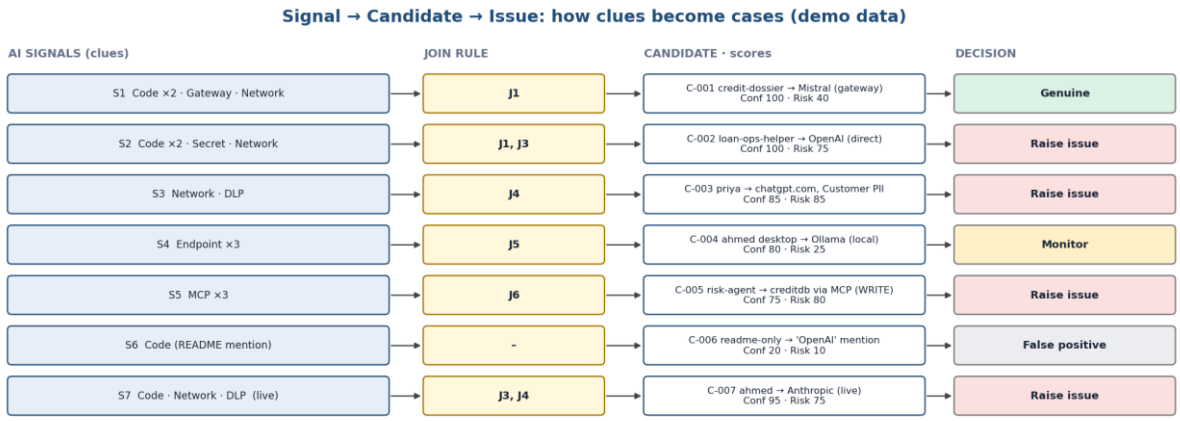


Figure 4 – How clues become candidates and decisions (demo data)

8.8 Reference data used by the demonstrator

Data	Content (fictional)
Approved AI inventory	AI-INV-1022 Credit Dossier GenAI (app = credit-dossier, route = gateway, Approved) AI-INV-1001 Microsoft 365 Copilot (Approved) · AI-INV-1030 Public ChatGPT (Restricted). loan-ops-helper, risk-agent and local runtimes are deliberately absent.
Repo register / CMDB	credit-dossier (Credit Technology, High, customer data) loan-ops-helper (Ravi Menon, High, customer data) readme-only (Sanjay Iyer, Low) treasury-reports (Treasury IT, Medium) creditdb (Credit Data Platform, High, customer data)
Demo identities	app-svc (Credit Technology) gateway-svc (Enterprise AI Platform) · dev-svc (Lending Technology) priya (Retail Lending) ahmed (Risk Analytics)

8.9 Mapping to the logical architecture

Wireframe element	Logical component	Note
7 collectors	C1 Source Connectors, C2 Normalization	Files and logs on the AVD instead of enterprise APIs
AI signature catalogue	C3 AI Catalogue	
Detect + join rules J1–J6	C4 Detection & Correlation	“Signals” are clues; “candidates” are findings
Inventory, repo register, CMDB	C5 Inventory Reconciliation	
Confidence and risk with reasons	C6 Scoring Engine	Rubric in 8.6
Decision rules R1–R4	C7 Governance & Policy	Simplified routing for the demo
Issues (Open → Investigating → Resolved)	C8 Case Management	“Issue” = case
Recommended action text	C9 Explanation Service	Pre-written per scenario; no GenAI
Seven screens	C10 API, C11 Dashboard / UI	See Appendix B
Run summary and decision counts	C12 Reporting & KPI	Demo-level only
–	C13 Audit & Evidence	Not shown in the wireframe

8.10 Alignment items for the development team

#	Item	Proposed handling
A1	Terms differ: wireframe uses signal / candidate / issue; SAD and requirements use event / finding / case	Use wireframe terms in the demo UI; keep a glossary mapping (Appendix A) *(proposed)*
A2	Decision rules R1–R4 differ from the Requirements v0.4 routing (Monitor / Investigate / Incident)	Keep R1–R4 for the demo; agree the production model (gap G10)
A3	Wireframe rubric (8.6) differs from prototype v0.2 points used in Section 3.5 examples	Adopt one rubric in config before the event (gap G10)
A4	Wireframe has no analyst status change with mandatory reason or audit view (FR-18, FR-19)	Acceptable for the demo; required for MVP
A5	Prototype v0.2 code does not yet have signal list, join-rule edges, clue map, R1–R4, S7 live run or issue lifecycle	Build these to match the wireframe (gap G11)
A6	Issue due date shown as “5 working days”	Demo value only; real SLAs TBD (FR-22)
A7	Wireframe aligned to “Codex Prompt v2”	Keep the prompt and wireframe under version control together *(proposed)*

9. Technology architecture

No technology is mandated and none is yet confirmed as enterprise approved. Choices are recommendations tied to requirements.

Component	Recommended	Why	Trade-off	Approved?
Language (C2–C9)	Python	Data, rules and AI libraries; prototype built	Slower than Java/.NET at very high volume	To confirm
API (C10)	FastAPI	Typed models, auto docs, async	Smaller enterprise base	To confirm
Dashboard (C11)	Demo: static HTML/JS (Wireframe v2); MVP: React	No build for demo; React scales	Build and patching effort	To confirm
Findings/cases store	Managed PostgreSQL	Relational joins, JSON support	Needs managed HA	To confirm
Audit store (C13)	Append-only table + immutable export	Tamper-evident	Extra storage set-up	To confirm
Ingestion	MVP: SIEM/APIs; scale: Event Hubs or Kafka	Reuses pipelines	SIEM API limits	To confirm
Correlation/scoring	Custom Python rules; weights in config	Explainable, calibratable	Needs tuning	In-house
Explanation (C9)	Templates; optional approved OpenAI/Mistral endpoint	Works without GenAI	GenAI governance needed	Use case to register
Identity (X1)	Bank IdP (Entra ID assumed)	SSO, RBAC, managed identity	Bank standard	Assumed
Secrets (X2)	Bank vault (Key Vault assumed)	Rotation, managed identity	–	Assumed
Hosting	Demo: AVD; target: managed containers (AKS if standard)	Portable, scalable	AKS ops skill	To confirm
Monitoring (X3)	Bank standard APM	Reuse ops tooling	–	To confirm
Cases (C8)	In-platform	Decided in v0.4	Some ITSM duplication	Decided

9.1 Demonstrator components (Wireframe v2)

Component	Used for	Scenario
AVD (C:\ShadowAI-Demo)	Isolated demo environment	All
LiteLLM gateway	Approved AI route with gateway logs	S1
Ollama with qwen2.5:0.5b	Local AI model, no internet traffic	S4
PostgreSQL (creditdb) + demo MCP server	Agent with read and write tools	S5
Proxy log + DLP add-on	Network and data-movement evidence	S2, S3, S7
s7_live.py	Live activity during the demo	S7

9.2 Architecture Decision Records

ADR	Decision	Status
ADR-001	Python + FastAPI for core and API	Accepted (prototype)

ADR	Decision	Status
ADR-002	Rule-based scoring; weights in config	Accepted
ADR-003	GenAI advisory and off by default	Accepted
ADR-004	Cases in platform; no ServiceNow	Accepted (v0.4)
ADR-005	Metadata only; secrets as fingerprints	Accepted
ADR-006	PostgreSQL as system of record	Proposed
ADR-007	Read from SIEM/source APIs first; streaming later	Proposed
ADR-008	Fictional data planted on an AVD for the demonstrator	Proposed
ADR-009	Managed containers on Bank-approved cloud	Proposed
ADR-010	Wireframe v2 is the UI and behaviour baseline for the demonstrator	Proposed

9.3 Proofs of concept

- Source access – read proxy, identity, DLP and secret metadata with read-only identities
- Correlation accuracy – correct joins, acceptable false positives (demo scenarios S1–S7 as test cases)
- Scale – ingestion keeps up with real proxy/SWG volume
- GenAI safety – only metadata sent; outputs logged

10. Data architecture

10.1 Data ownership

Data entity	Owning component	Business owner	Classification	Retention
Raw source events	Source systems (not copied in full)	Source owner	Confidential	At source
Normalized events / signals	C2, C4	Platform team	Confidential	[TBD –to confirm]
AI Catalogue	C3	AI Governance *(proposed)*	Internal	Versioned
Findings / candidates	C4	AI Governance	Confidential	[TBD –to confirm]
Scores	C6	AI Governance / Risk	Internal / Confidential	With finding
Status and decisions	C7	AI Governance	Internal	With finding
Cases / issues and exceptions	C8	Asset owner	Confidential	[TBD –to confirm]
Audit log	C13	Risk / Compliance	Confidential	Records policy [TBD –to confirm]
AI inventory, CMDB	External	Their owners	Internal / Confidential	Not managed here

10.2 Field classification

Fields	Classification	Handling
Discovery ID, asset type, provider, method, first/last seen, status, inventory ID	Internal	Standard
User/workload/owner, device/resource, destination/endpoint	Confidential	RBAC; aggregated for leadership
Data classification, movement summary, evidence references	Confidential	Metadata only
Risk score, case/owner/due date	Confidential	RBAC
Credential fingerprint	Restricted	Raw secrets never stored

10.3 Data lifecycle

Collect (read-only, metadata) → Normalise → Correlate → Enrich (inventory, owner, criticality) → Score → Decide → Case → Close → Retain → Purge. Every write is audited. Content is reviewed only through an authorised case.

10.4 Demonstrator data entities

Entity	Key fields (from Wireframe v2)
Signal	ID, channel, signal type, what was detected, entity, user/device, provider, source path, candidate ID
Candidate	ID, scenario, name, linked signals, edges (from, to, join rule, shared value), inventory result, confidence factors, risk factors, decision rule fired, suggested owner, recommended action
Issue	ID, candidate ID, title, status (Open, Investigating, Resolved), resolution, new-from-live flag
Run	Collector item counts, stage counts, timestamp, includes-S7 flag

11. Integration architecture

ID	Interface	Style	Minimum permission / auth	Phase
INT-01	Proxy / SWG / DNS	Async: streaming, API or SIEM	Read logs; managed identity	MVP
INT-02	Identity / OAuth	Async: Graph or IAM API	Read directory, audit, grants	MVP
INT-03	Secret scanning	Async: API, webhook or SIEM	Read findings, no secret values	MVP
INT-04	DLP	Async: API or SIEM	Read alerts and labels	MVP
INT-05	Cloud control plane	Async: cloud API or CNAPP	Read-only inventory and audit	MVP
INT-06	Endpoint / IDE	Async: EDR API	Security reader; no execution	Phase 3
INT-07	Code / dependencies	Async: API, webhook, CI	Read findings and dependencies	Phase 3
INT-08	AI gateway	Async: telemetry	Read logs; prompts excluded	Phase 3
INT-09	SaaS / CASB	Async: CASB API	Read app discovery and activity	Phase 3
INT-10	Agents / MCP	Async: telemetry/API	Read metadata and grants	Phase 4
INT-11	Procurement / expense	Async: daily batch	Read metadata; card details masked	Phase 5
INT-12	AI inventory	Async, scheduled	Read-only	MVP
INT-13	CMDB	Async, scheduled	Read-only	MVP
INT-14	Dashboard → API	Sync REST/JSON	SSO (OIDC) + RBAC + MFA	Demo/MVP
INT-15	Explanation → GenAI	Sync, optional	Managed identity; metadata only	Optional
INT-16	Owner notification	Async	Service identity	MVP
INT-17	GRC / SIEM / SOAR	Async	Scoped write	Phase 5

11.1 Integration rules

- Sources are async so the platform never slows them down; user actions are sync.
- Every message carry event ID, source, timestamp and schema version.
- Processing is idempotent: replays update a finding but never duplicate it.
- A failed connector marks its source as stale and does not stop the pipeline.
- Demonstrator: collectors read local files and log on the AVD only; no enterprise integration.

12. Security architecture

12.1 Threat model (STRIDE)

Threat	Example	Control
Spoofing	Fake connector sends events	Managed identities; mutual TLS or signed webhooks; source allow-list
Tampering	Evidence or audit edited	Append-only audit; immutable export
Repudiation	“I didn't approve that”	User, time, reason, before/after on every action
Information disclosure	User activity or fingerprints leaked	Metadata only; RBAC; encryption
Denial of service	Event flood	Queue buffering, rate limits, scale-out
Elevation of privilege	Discovery identity used to block	Separate identities; no admin rights
AI-specific	Prompt injection; invented facts	Cleaned inputs; metadata-only prompts; GenAI never decides; logged

12.2 Layered controls

Layer	Controls
Identity	SSO + MFA; managed identities; read-only connector roles; discovery separate from enforcement
Network	Private endpoints; no public database; outbound only to approved sources and GenAI endpoint
Application	Input validation; role checks on every call; secure headers; dependency scanning
Data	TLS 1.2+; encryption at rest; field-level RBAC; fingerprints only; retention [TBD – Bank to confirm]
Secrets	Vault; rotation; no hard-coded credentials
AI	Approved endpoint; metadata only; advisory; logged; works without GenAI
Monitoring and audit	Platform logs to Bank SIEM; alerts on unusual activity; tamper-evident audit
Governance	Permissions validated by platform owners; Privacy/Legal approval before new sources (FR-24)

12.3 Zero Trust

Principle	Application
Verify explicitly	Every user and service authenticated on every call
Least privilege	Read-only connectors; RBAC; content only via a case
Assume breach	Separate identities; immutable audit; encryption; SIEM monitoring of the platform

12.4 AI safety of the platform's own GenAI

- GENAI-01 Registered in the approved AI inventory before go-live
- GENAI-02 Only metadata sent to the model
- GENAI-03 Advisory only; rules decide
- GENAI-04 Human review before action
- GENAI-05 All inputs and outputs logged
- GENAI-06 Approved enterprise endpoint only
- GENAI-07 Platform works fully without GenAI (template fallback)

12.5 Employee monitoring and privacy

- Privacy, Legal and HR approve each telemetry source before activation
- Transparency notice to employees; privacy impact assessment before go-live
- User-level data limited to authorised roles; leadership reports aggregated
- Purpose limited to AI governance and security; not used for performance evaluation

12.6 Demonstrator safeguards

- Fictional identities and data only (14 fake account numbers in S3)
- DEMO key in git history only; key shown as a fingerprint
- Scanning limited to C:\ShadowAI-Demo
- No prompts, file contents or key values stored

13. Deployment and operations

Demonstrator: runs on a single AVD with local services (Section 9.1). Target: hosting, cloud, region and environment standards aren't confirmed, so the design below is proposed, assuming a Bank-approved cloud (likely Azure).

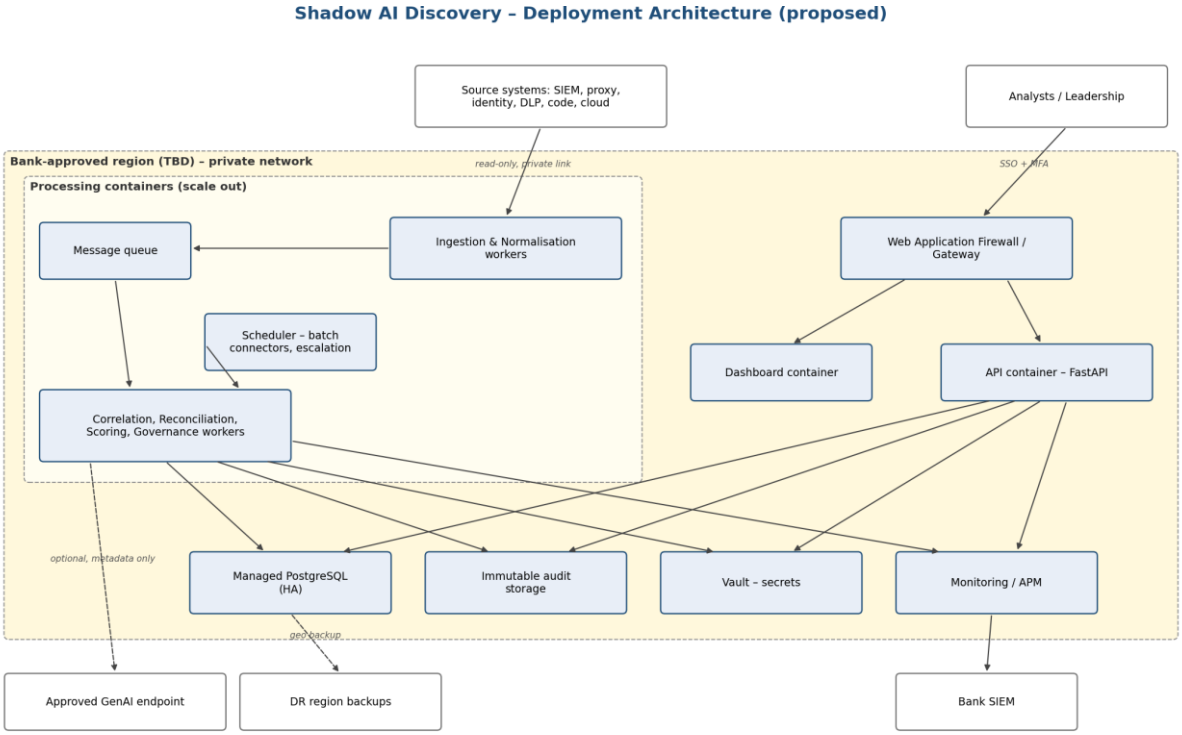


Figure 2 – Deployment architecture (proposed)

13.1 Hosting

Element	Approach
Compute	Managed containers (or AKS if the Bank standard); same image in every environment
Containers	UI, API, ingestion workers, engine workers, scheduler – each scale independently
Database	Managed PostgreSQL, zone-redundant HA
Queue	Managed message queue between ingestion and engine
Audit	Append-only table + immutable storage
Network	Private endpoints; WAF/gateway for users; no public database
Secrets	Bank vault with managed identity
Region	Bank-approved [TBD –to confirm]

13.2 Environments

Environment	Purpose	Data
Demo (AVD)	UK event demonstrator	Fictional, planted S1–S7
Dev	Build and unit test	Simulated
Test	Integration and correlation testing	Simulated + test connectors
UAT	Acceptance and score calibration	Masked or approved sample
Prod	Live discovery	Real metadata, read-only

Promotion: the same container image moves Dev → Prod; UAT and Prod need approval gates; catalogue and weight changes are promoted as versioned configuration.

13.3 CI/CD

Stage	Checks
Build	Lint, type checks, unit tests
Security	Dependency, container and secret scans; static analysis
Package	Versioned image to private registry
Deploy Dev/Test	Automatic; infrastructure as code
Test	Integration, correlation scenarios (S1–S7 expected decisions), false-positive checks
UAT / Prod	Manual approval; change record; blue/green or rolling with automatic rollback

13.4 Scaling and observability

Area	Approach
Scaling	Ingestion and engine workers scale on queue backlog; API on load; DB scale-up and read replicas
Health	API uptime, restarts; alert below 99.5% *(proposed)*
Pipeline	Queue length, event-to-finding time; alert above 15 minutes *(proposed)*
Connectors	Last successful read; alert when stale
Quality	Findings per day, false-positive rate
Cases	Overdue cases
Security	Failed sign-ins, unusual exports, rule changes → SIEM
GenAI	Calls, errors, fallback rate

13.5 Backup and disaster recovery

Item	Approach	Target
Database	Automated backups, point-in-time restore, geo copy	RPO ≤ 1 h *(proposed)*
Audit log	Immutable, replicated	Zero loss
Configuration	Git; redeploy from pipeline	Fully restorable
Platform	Infrastructure as code + images	RTO ≤ 4 h *(proposed)*
Raw events	Re-read from sources or SIEM	Rebuilt
DR test	Restore drill every 6 months *(proposed)*	Documented

13.6 Run model

Activity	Owner
Platform health, patching, DR	Infra / SRE
Pipelines and releases	DevOps
Connector failures	Platform team with source owner
Catalogue updates	AI Governance (owner); Platform team (deploys)
Score calibration	AI Governance / Risk
Runbooks	Stale connector, queue backlog, DB failover, GenAI outage, restore

14. Failure and risk analysis

14.1 Failure modes

#	Failure	Response
F1	Source connector down	Isolated; source marked stale; re-read from checkpoint
F2	Bad or changed source data	Schema validation; dead-letter queue; replay
F3/F4	Ingestion workers or queue	Queue buffering; auto-scale; zone-redundant queue; replay
F5	Bad catalogue entry	Versioned config; review; rollback
F6	Correlation bug	Idempotent processing; regression tests; rollback and reprocess
F7	Inventory/CMDB unavailable	Cached copy; “reconciliation pending”; no auto cases on stale data
F8/F9	Scoring or rules misconfigured	Versioned weights and rules; UAT calibration; rollback
F10	Notifications fail	Retry, outbox, overdue alert
F11	GenAI down or wrong	Template fallback; never affects score or status
F12	Database failure	HA failover; PITR; geo backup
F13	Audit store failure	Analyst writes fail closed; restore from immutable copy
F14	API/UI down	Multiple instances; health probes
F15/F16	IdP or vault down	Bank HA; break-glass with audit; cached tokens
F17	Region outage	DR regions rebuild from IaC and backups

14.2 SPOFs, bottlenecks and lock-in

Type	Item	Mitigation
SPOF	Database	Zone-redundant HA, PITR, geo backup
SPOF	Approved AI inventory	Cache; pending state; named owner
SPOF	Key people	Owner + deputy; runbooks
Bottleneck	Proxy/SWG volume	Filter to AI destinations at source; partitioned queue; scale PoC
Bottleneck	Analyst capacity	Banding, false-positive suppression, cases only where needed
Lock-in	Cloud	Containers, PostgreSQL, IaC
Lock-in	GenAI provider	Single interface; templates; two approved providers
Cost	Logs and GenAI	Metadata only; retention; autoscale limits; GenAI off by default

14.3 Risk register

ID	Risk	L	I	Mitigation	Owner
R1	Demonstrator not ready for event	M	H	Limit scope to Wireframe v2; prototype working	Solution Architect
R2	No reliable AI inventory	M	H	Phase 1 baseline; cache; owner	AI Governance
R3	Poor CMDB ownership	H	M	Ownership tasks; quality KPI	CMDB owner
R4	TLS/unmanaged devices hide usage	H	M	Multi-source correlation; policy	Security
R5	Too many false positives	M	H	Correlation; FP loop; calibration	AI Governance
R6	Proxy volume exceeds capacity	M	M	Filter at source; scale PoC	SRE

ID	Risk	L	I	Mitigation	Owner
R7	Privacy/HR objection	M	H	FR-24 gate; metadata only; notice	Privacy/Legal
R8	Discovery identity misused	L	H	Separate read-only identities	Security
R9	Audit tampering or loss	L	H	Immutable replicated audit	Security
R10	GenAI wrong or sensitive output	L	M	Metadata only; advisory; logged	AI Governance
R11	Source API changes	M	M	Schema versioning; contract tests	Platform team
R12	Catalogue goes stale	H	M	Owner and update cycle	AI Governance
R13	Cost growth	M	M	Limits and alerts	Platform owner
R14	DR region breaks residency	L	H	Residency-compliant DR	EA / Security
R15	Live S7 step fails during the event	M	M	Rehearse on the AVD; baseline S1–S6 run still tells the story	Demo lead

Likelihood and impact ratings are proposed and need SRE and Security review.

15. Validation and traceability

Every functional requirement map to at least one component, and every component traces back to a requirement. Seven items are only partly covered, and seven NFR targets remain TBD. ARB review has not yet taken place.

15.1 Traceability summary

Requirements	Components / controls	Result
FR-01 to FR-14, FR-16, FR-18 to FR-21, FR-25	C1–C13, X1	Traced
FR-15 Agents/MCP/AI BOM	C1 (INT-10), C4; demo S5	Partial – AI BOM model not designed
FR-17 GRC/SIEM/SOAR	INT-17	Partial – contract not defined
FR-22 Notification and escalation	C8, INT-16	Partial – channel and SLAs not chosen
FR-23 KPIs	C12	Partial – targets TBD
FR-24 Source approval gate	C1 + process	Partial – technical gate not designed
NFR-01 to NFR-08, NFR-17	X1, X2, C13, connector interface	Traced (NFR-05 partial)
NFR-09 to NFR-16	Queue, HA, DR, lifecycle	Targets TBD
GENAI-01 to GENAI-07	C9, C13, INT-15	Traced (GENAI-01 pending registration)

15.2 Gaps to close before sign-off

Gap	Action	Owner
G1	Agree NFR-09 to NFR-16 targets	EA, Infra, Risk
G2	Design AI BOM data model	Solution Architect
G3	Define GRC/SIEM/SOAR contract	Integration Architect
G4	Choose notification channel and case SLAs	AI Governance
G5	Design technical source-approval gate	Solution Architect, Privacy
G6	Design case-based content-access flow	Security
G7	Set KPI targets	AI Governance
G8	Register GenAI component	AI Governance
G9	Confirm inventory and CMDB owners	AI Governance, CMDB owner
G10	Agree one decision model and one scoring rubric (wireframe R1–R4 and 8.6 vs requirements routing and 3.5)	AI Governance, Solution Architect
G11	Build wireframe features in the prototype: signals, join edges, clue map, R1–R4, S7 live run, issue lifecycle	Development team

15.3 Sign-off

Reviewer	Scope	Status
Architecture Review Board	Overall architecture, ADRs, traceability	Not yet submitted
Enterprise Architecture	Technology and hosting	Pending
Security Architecture	Threat model, identities, controls	Pending
Privacy / Legal / HR	Monitoring sources, retention	Pending
AI Governance	Catalogue, scoring, GenAI	Pending

Reviewer	Scope	Status
Risk & Compliance	Regulatory mapping	Pending
Business sponsor	Scope and demonstrator outcome	Pending

15.4 Demonstrator vs target

The demonstrator (Section 8) does not implement sign-in, persistent storage, a tamper-evident audit log, analyst status changes with a reason, real SLAs, escalation or exception expiry. It does show metadata-only evidence, fingerprint-only keys, multi-channel collection, join rules with an over-merge guard, separate scores with reasons, inventory reconciliation, rule-based decisions, issue tracking and live detection (S7).

16. Roadmap

Phase	Focus	Done when
0. Event demonstrator	Wireframe v2 on the AVD; scenarios S1–S7	Baseline gives 6 candidates and 3 issues; S7 adds 1 new issue; before the event [TBD – Bank to confirm]
1. Foundation	Inventory, event schema, catalogue, privacy and access rules	Inventory and ownership established
2. MVP	Network, SSO/OAuth, secrets, DLP, cloud	Test scenarios detected; FP handling works
3. Expanded coverage	Endpoint, IDE, code, AI gateway, SaaS	Coverage accepted; monitoring governance approved
4. Agents and MCP	Agents, MCP servers, machine identities	Unknown privileged agents auto-routed
5. Optimization	Procurement, UEBA, GRC/SIEM/SOAR	Stable calibration; auditable evidence

17. Open questions

#	Question
Q1	Which SWG/proxy, DLP, CASB and EDR products are in use?
Q2	Who owns the approved AI inventory, and where is it held?
Q3	Which regions apply for data residency?
Q4	Which GRC tool, if any, should receive findings later?
Q5	Is works-council consultation required?
Q6	What are case SLAs and escalation paths?
Q7	Which retention periods apply?
Q8	What is the confirmed event date and name?
Q9	What is the full approved AI list beyond OpenAI and Mistral?
Q10	What is the budget for the demonstrator and MVP?
Q11	Which cloud, database and hosting products are enterprise-approved?
Q12	Which decision model and scoring rubric are authoritative for the MVP (gap G10)?

Appendix A. Glossary

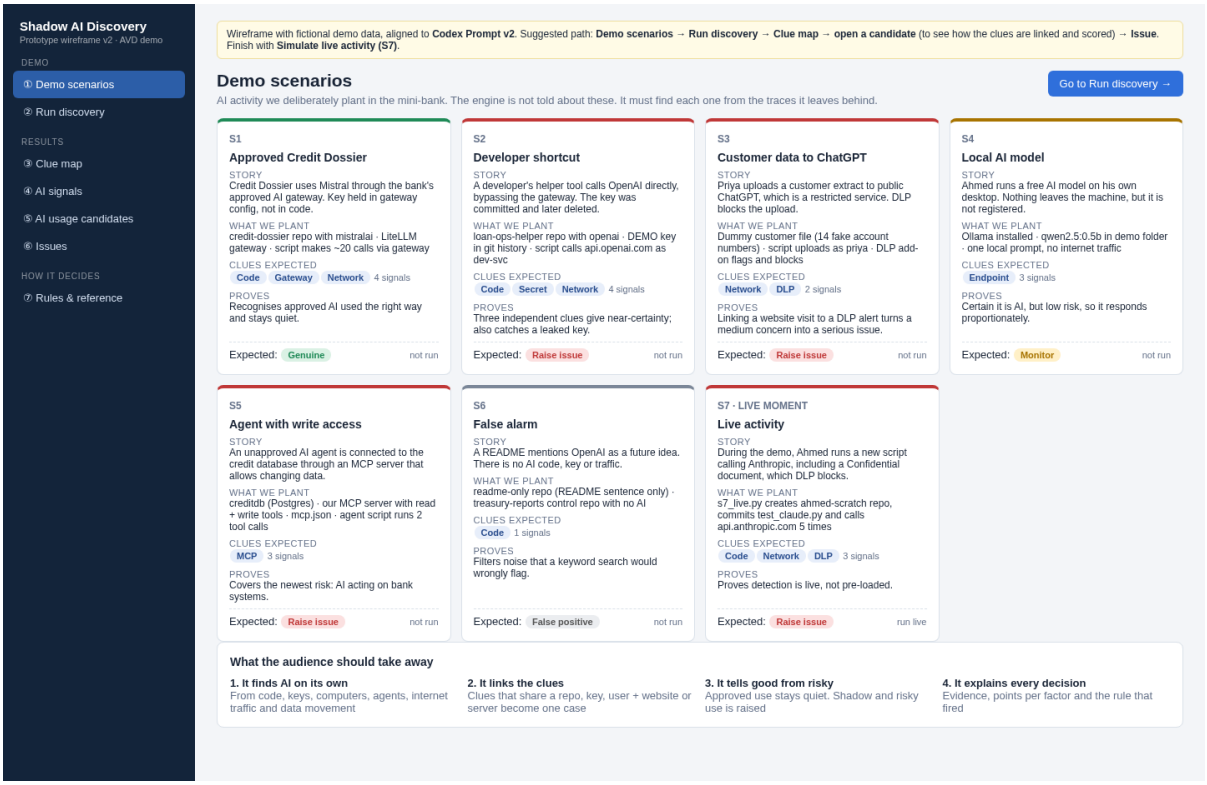
Term	Meaning
Shadow AI	AI used without approval from the Bank's AI governance process
Approved AI	Known, allowed AI usage, e.g. approved OpenAI or Mistral APIs
Signal (clue)	One item that matched the AI signature catalogue; on its own only a hint
Candidate	Group of linked signals; one suspected AI usage (= finding)
Issue	Candidate raised for investigation (= case)
Join rule	Rule that links two signals through a shared value (J1–J6)
Correlation	Joining several clues to confirm a finding
Reconciliation	Checking a finding against the approved inventory
Confidence score	How sure we are that AI is really being used (0–100)
Risk score	How much harm the AI use could cause if real (0–100)
MCP server	Service that lets AI agents use tools and data
AI BOM	List of AI components: models, tools and permissions
AVD	Azure Virtual Desktop used as the demo environment
DLP / CASB	Data Loss Prevention / Cloud Access Security Broker
SIEM / SOAR	Security log analysis / automated response
ADR	Architecture Decision Record
RPO / RTO	Maximum data loss / maximum time to restore
SPOF	Single point of failure

Appendix B. Screen catalogue (Wireframe v2) for development

Screenshots were captured from Shadow_AI_Discovery_Wireframe_v2.html with its fictional demo data. Suggested demo path: Demo scenarios → Run discovery → Clue map → open a candidate → Issue, then Simulate live activity (S7). API endpoints listed are proposed for the build and are not yet in prototype v0.2 unless stated.

B.1 Demo scenarios

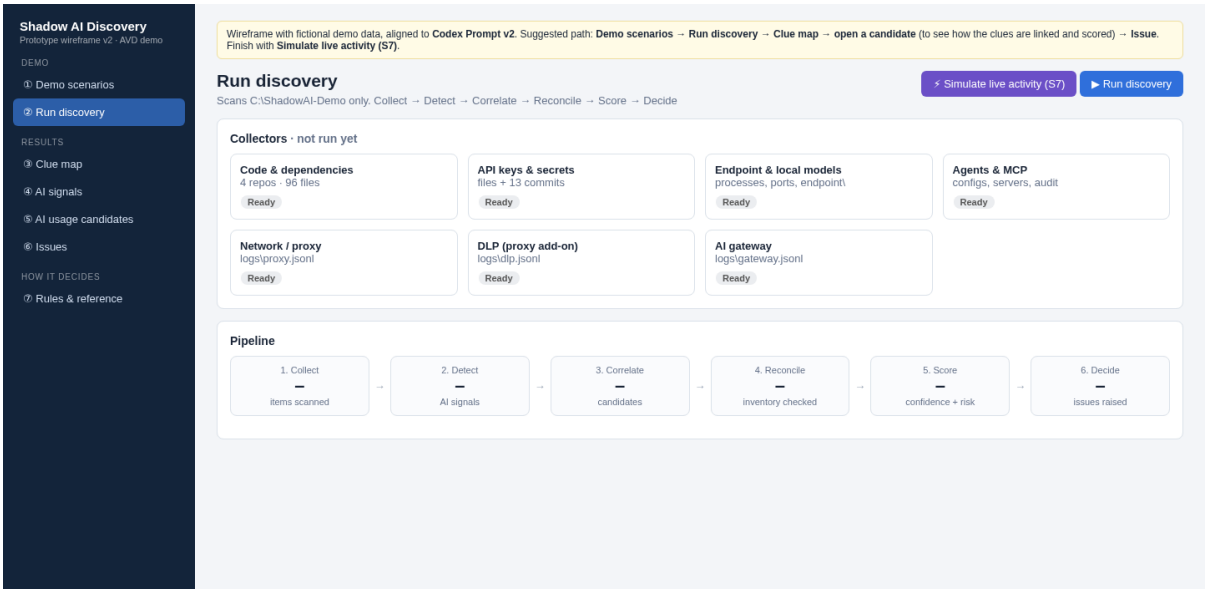
Item	Detail
Purpose	Introduce the seven planted scenarios before the run.
Key elements	Cards S1–S7: story, what is planted, expected clue channels, what it proves, expected decision; link to result after the run; audience takeaways.
Data / API	GET /api/scenarios *(proposed)*
Requirements	FR-25



Screen B.1 Demo scenarios

B.2 Run discovery – before the run

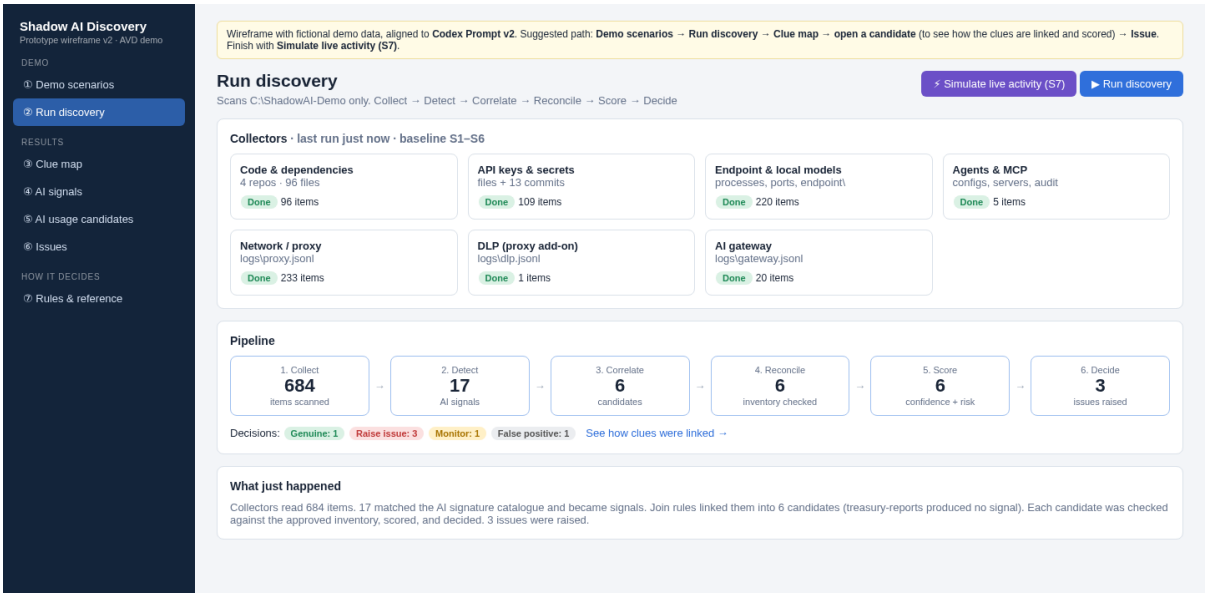
Item	Detail
Purpose	Show the collectors and the empty pipeline.
Key elements	Seven collector cards (Ready); six pipeline stages; Run discovery and Simulate live activity (S7) buttons.
Data / API	POST /api/discovery/run (exists in v0.2; extend for stage counts)
Requirements	FR-01, FR-04



Screen B.2 Run discovery – before the run

B.3 Run discovery – after the baseline run

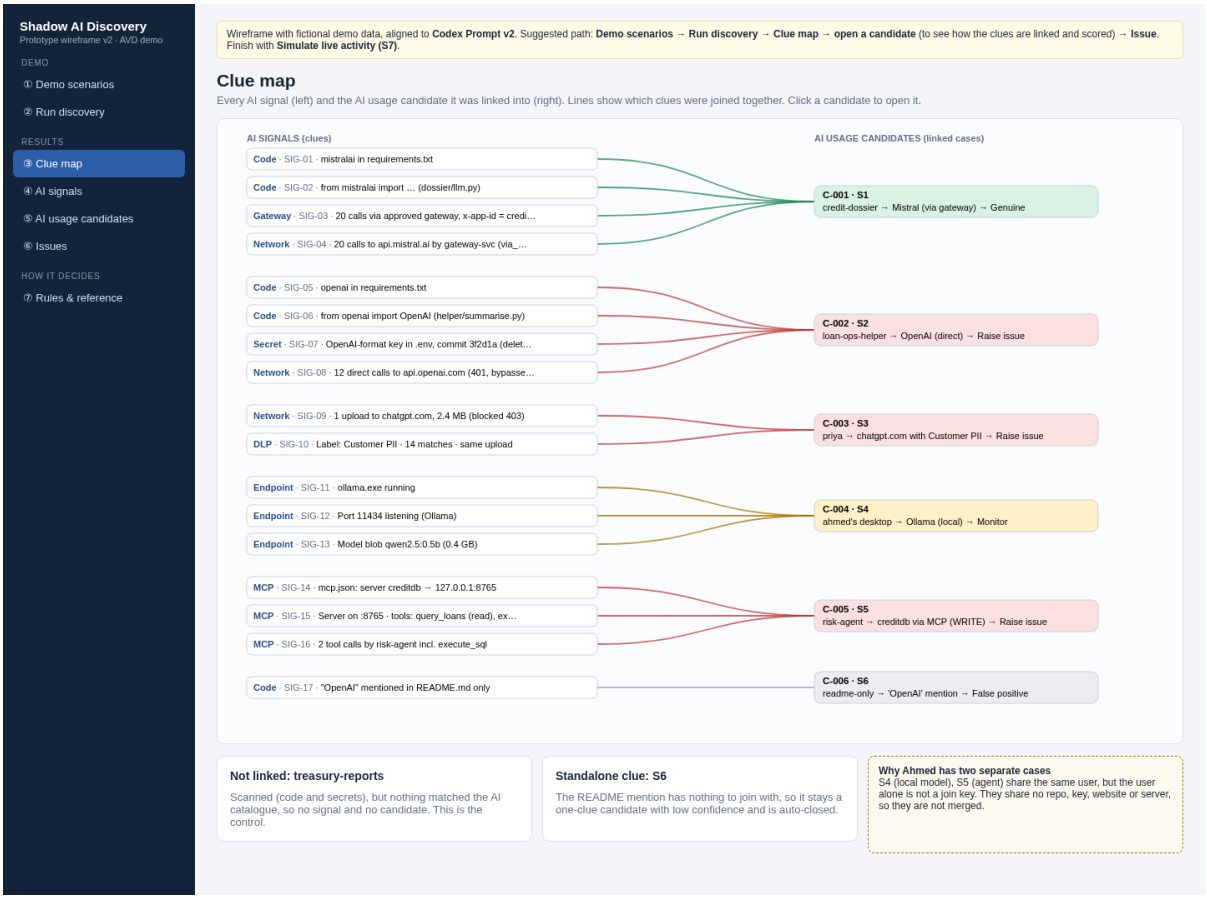
Item	Detail
Purpose	Show what the engine found.
Key elements	Collector counts; stage counts 684 → 17 → 6 → 6 → 6 → 3; decision summary (Genuine 1, Raise issue 3, Monitor 1, False positive 1); “What just happened” text.
Data / API	GET /api/runs/latest *(proposed)*
Requirements	FR-12, FR-23



Screen B.3 Run discovery – after the baseline run

B.4 Clue map

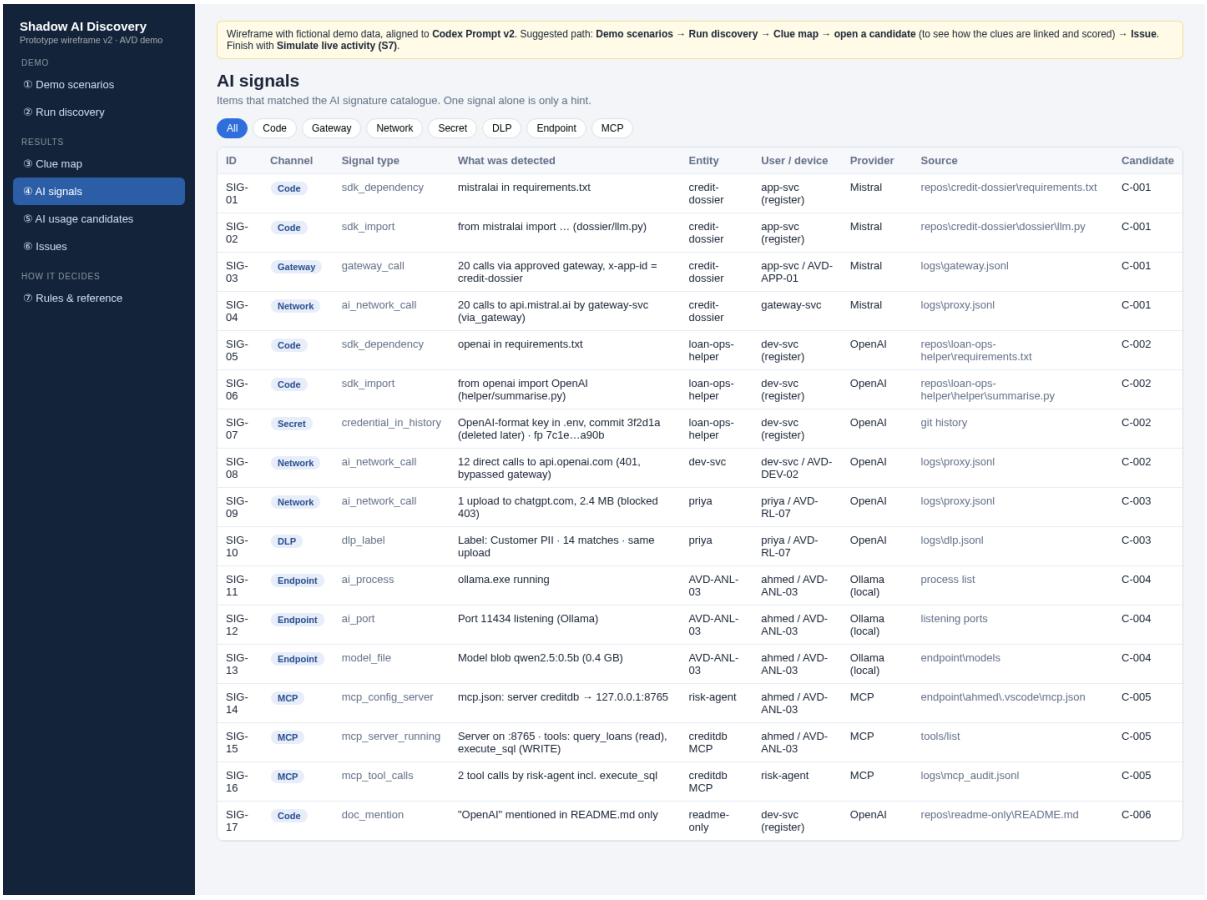
Item	Detail
Purpose	Show visually how clues were joined into cases.
Key elements	Signals on the left, candidates on the right, lines coloured by decision; notes on the control repo, the standalone S6 clue and the over-merge guard.
Data / API	GET /api/candidates?include=signals *(proposed)*
Requirements	FR-05, FR-06



Screen B.4 Clue map

B.5 AI signals

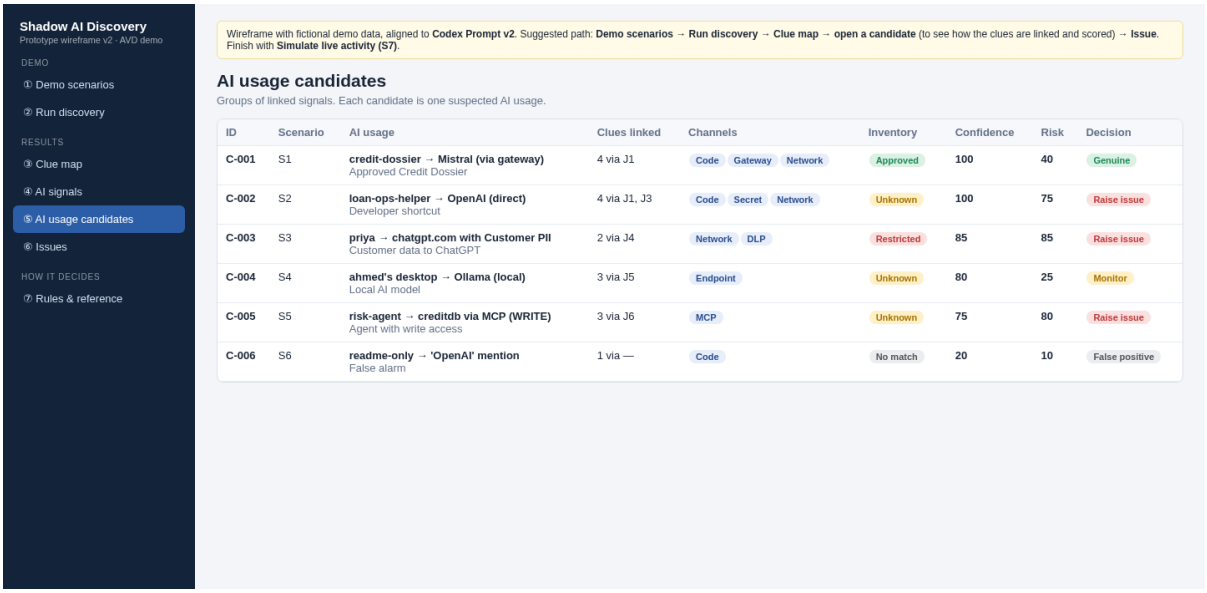
Item	Detail
Purpose	List every matched clue.
Key elements	Channel filter; columns ID, channel, signal type, what was detected, entity, user/device, provider, source, candidate; row opens candidate.
Data / API	GET /api/signals?channel= *(proposed)*
Requirements	FR-03, FR-04



Screen B.5 AI signals

B.6 AI usage candidates

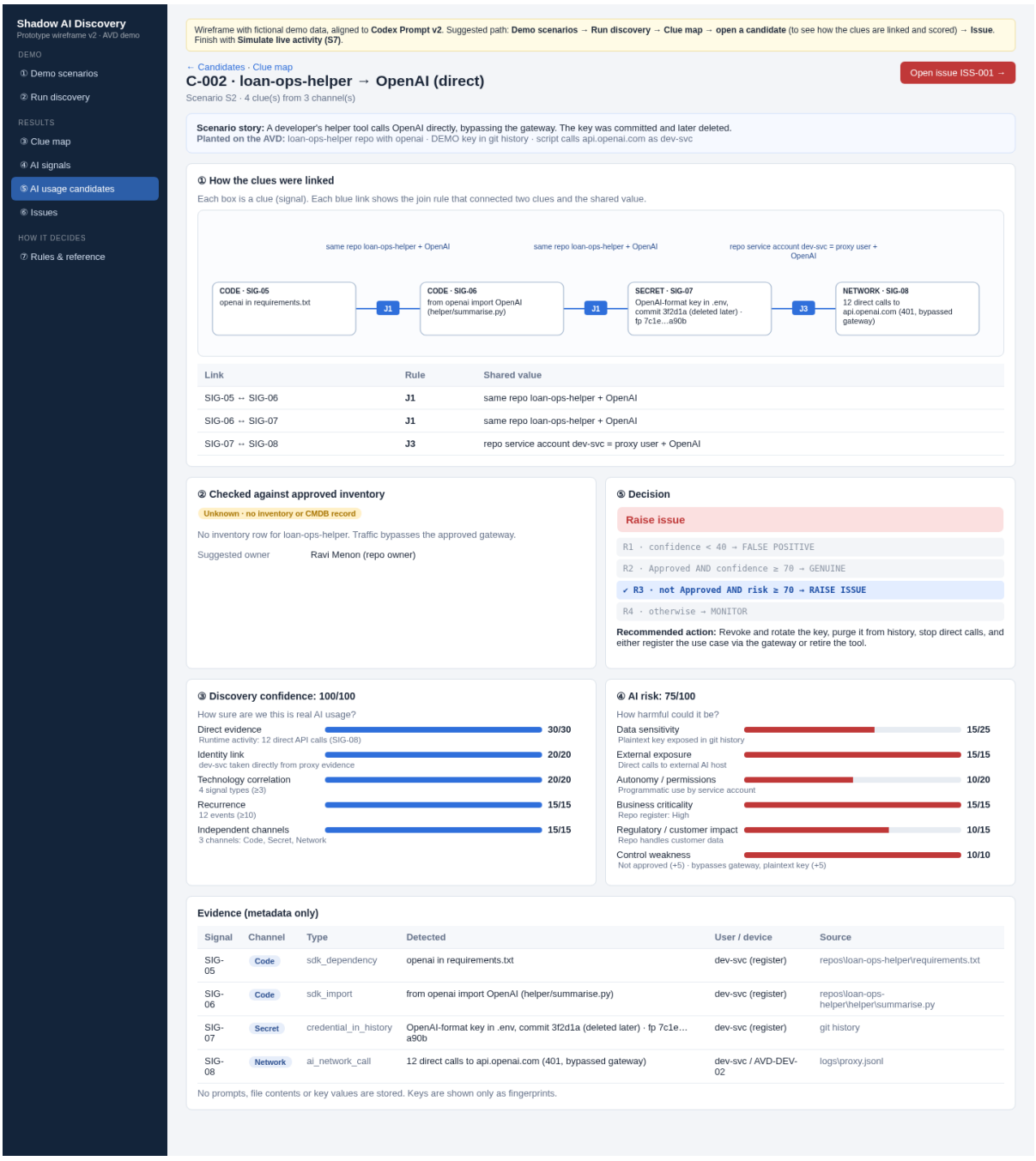
Item	Detail
Purpose	List suspected AI usages with scores and decisions.
Key elements	Columns ID, scenario, AI usage, clues linked and join rules, channels, inventory result, confidence, risk, decision.
Data / API	GET /api/candidates (proposed; v0.2 has /api/findings)
Requirements	FR-07 to FR-10



Screen B.6 AI usage candidates

B.7 Candidate detail (C-002 example)

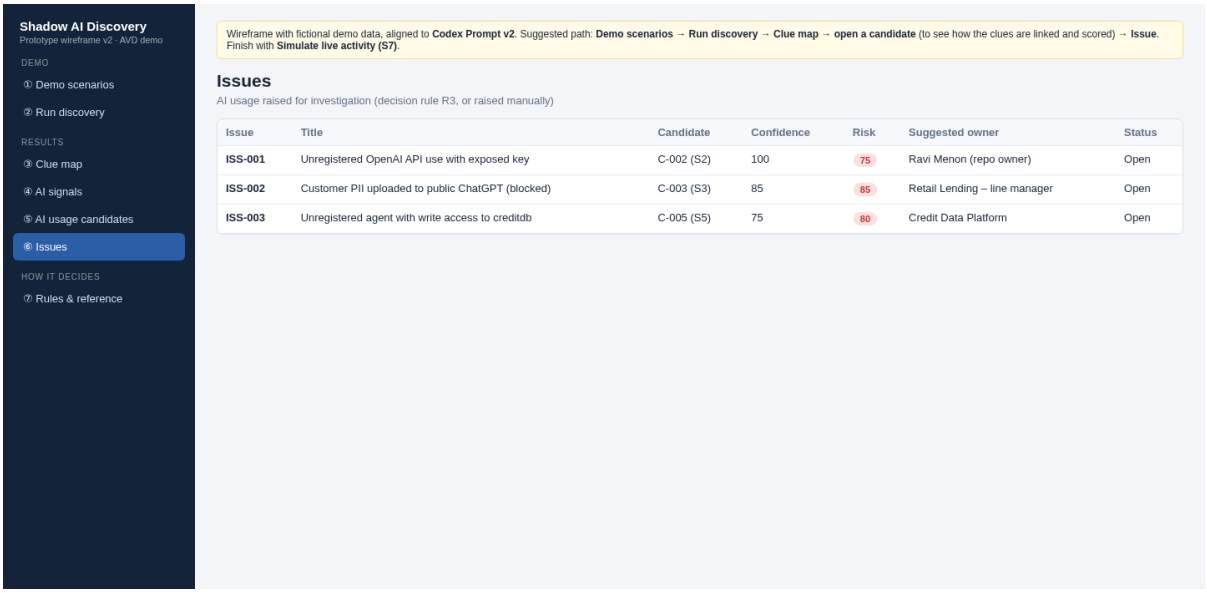
Item	Detail
Purpose	Explain one decision end to end.
Key elements	① link graph with join rules and shared values; ② inventory check and suggested owner; ③ confidence bars with reasons; ④ risk bars with reasons; ⑤ decision with the rule that fired and recommended action; evidence table (metadata only); Open issue / Raise issue manually.
Data / API	GET /api/candidates/{id}; POST /api/issues *(proposed)*
Requirements	FR-05, FR-07, FR-08, FR-09, FR-25



Screen B.7 Candidate detail (C-002 example)

B.8 Issues

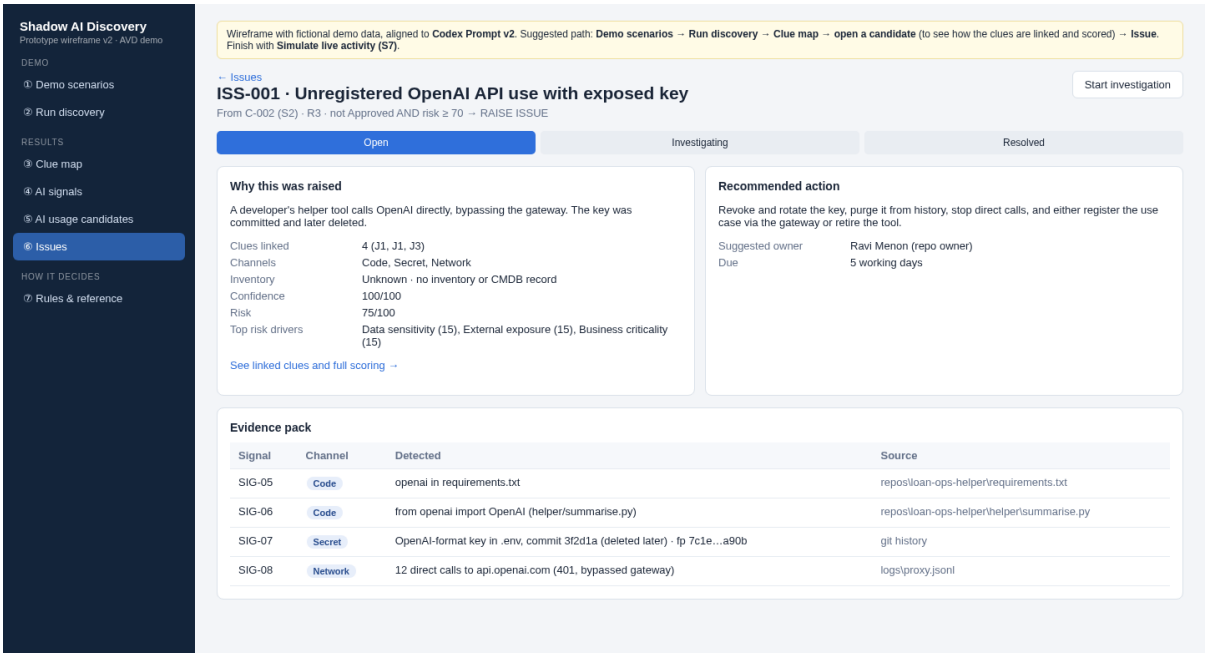
Item	Detail
Purpose	List AI usage raised for investigation.
Key elements	Columns issue, title, candidate, confidence, risk, suggested owner, status.
Data / API	GET /api/issues (proposed; v0.2 has /api/cases)
Requirements	FR-11



Screen B.8 Issues

B.9 Issue detail

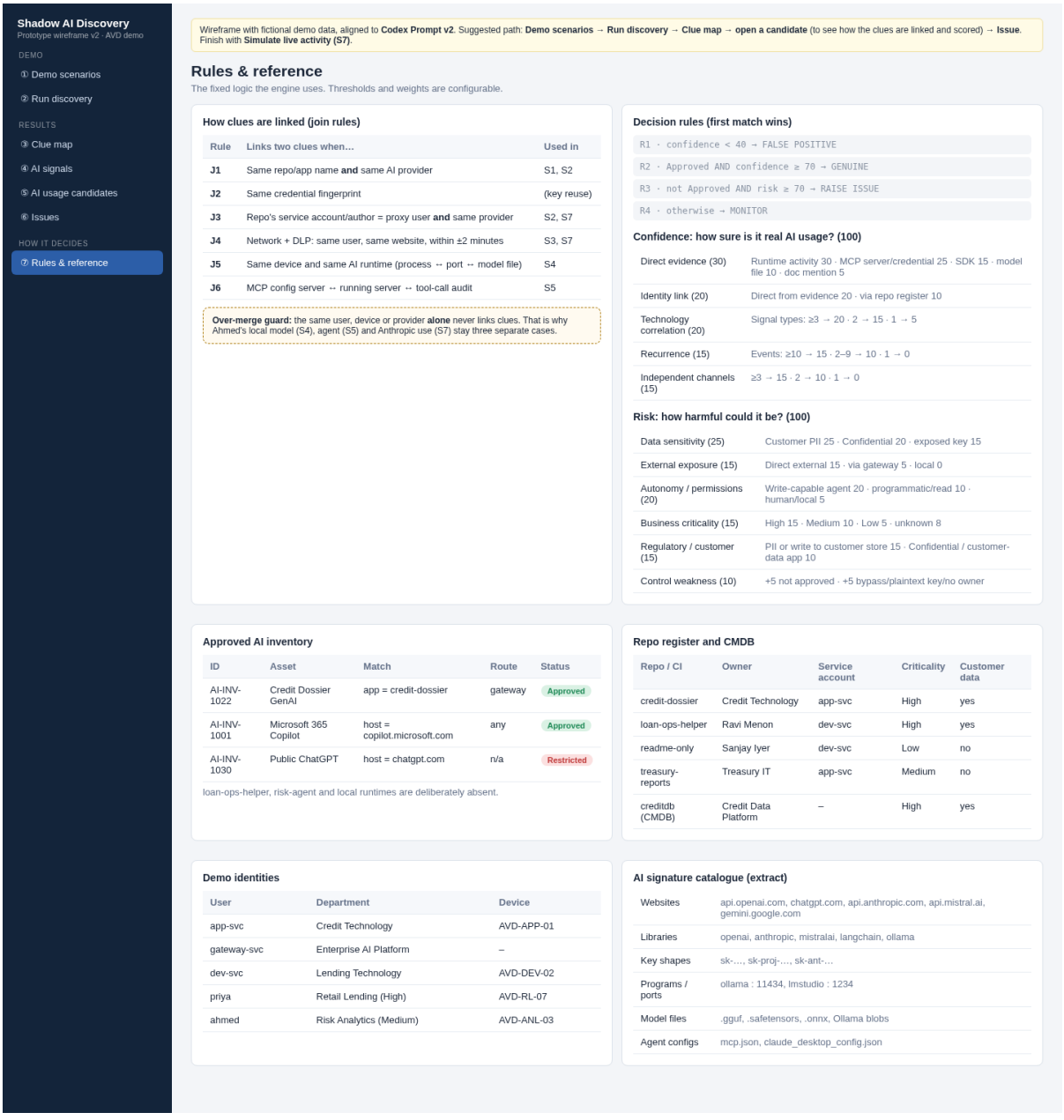
Item	Detail
Purpose	Work an issue through its lifecycle.
Key elements	Open → Investigating → Resolved steps; why raised; top risk drivers; recommended action; owner; due date (demo value); resolution choice; evidence pack.
Data / API	PATCH /api/issues/{id} *(proposed)*
Requirements	FR-11, FR-22



Screen B.9 Issue detail

B.10 Rules & reference

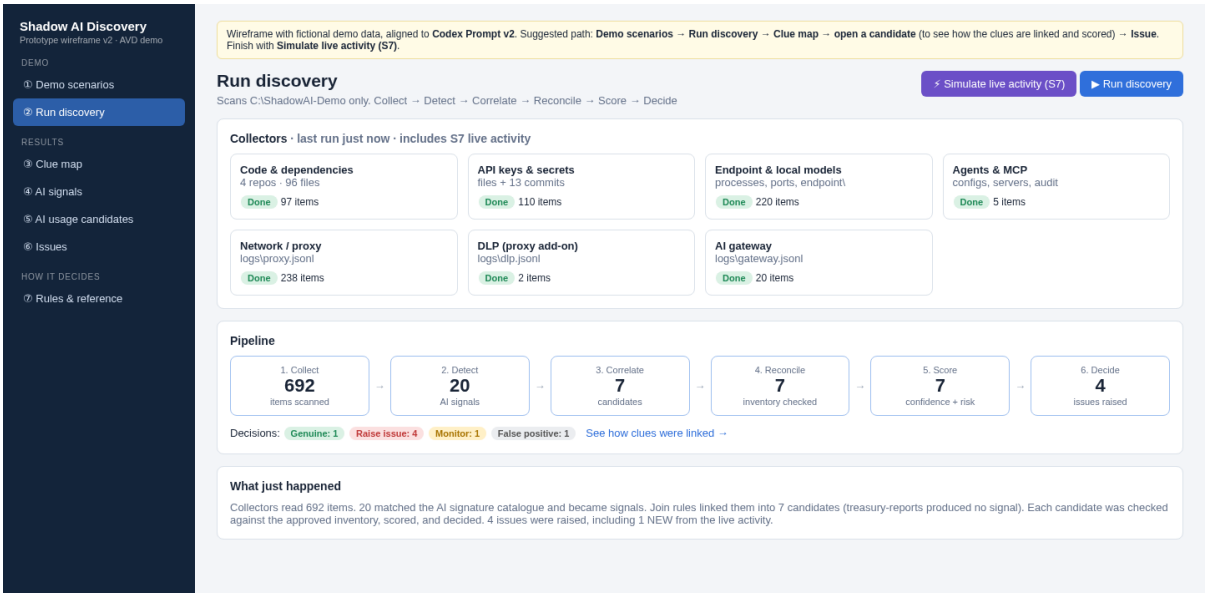
Item	Detail
Purpose	Show the fixed logic and reference data.
Key elements	Join rules J1–J6 with over-merge guard; decision rules R1–R4; scoring rubric; approved inventory; repo register and CMDB; demo identities; signature catalogue extract.
Data / API	GET /api/reference (proposed; v0.2 has /api/catalog, /api/inventory)
Requirements	FR-03, FR-20



Screen B.10 Rules & reference

B.11 Run discovery – after live activity (S7)

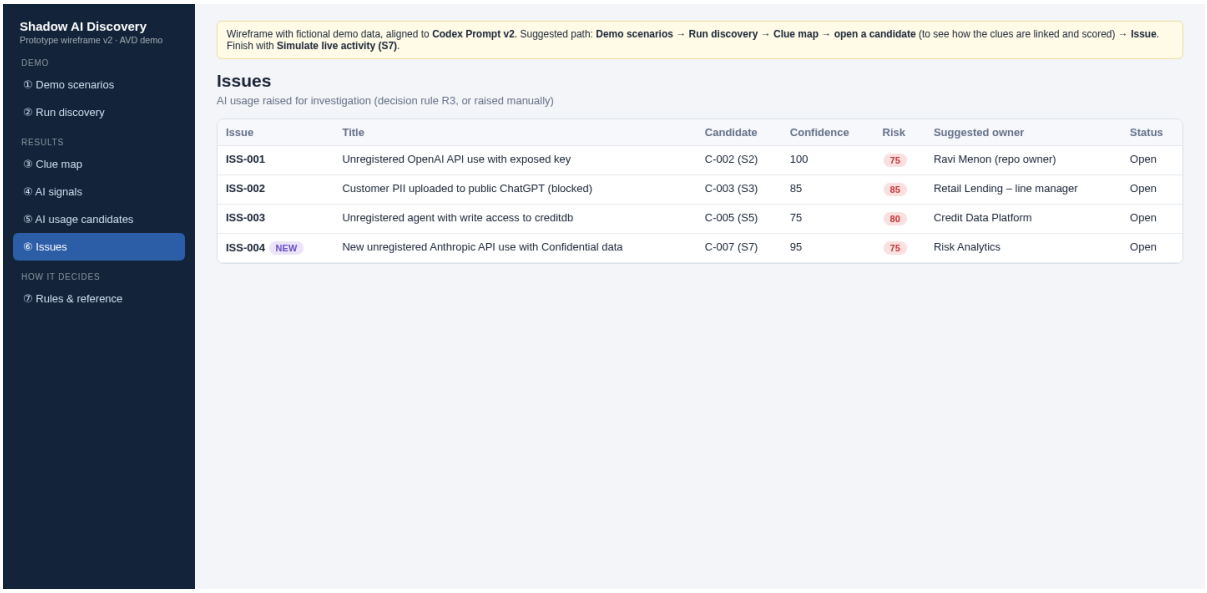
Item	Detail
Purpose	Prove detection is live, not pre-loaded.
Key elements	Run info shows S7 included; extra collector items; counts rise to 7 candidates and 4 issues.
Data / API	POST /api/demo/s7 (demo only, proposed) then POST /api/discovery/run
Requirements	FR-04, FR-05



Screen B.11 Run discovery – after live activity (S7)

B.12 Issues after S7

Item	Detail
Purpose	Show the new issue from live activity.
Key elements	New issue for Anthropic use with Confidential data, marked NEW.
Data / API	GET /api/issues
Requirements	FR-11



Screen B.12 Issues after S7